Einleitung

Willkommen zum Lernfeld 04! In den vergangenen drei Wochen hat sich unsere Gruppe 11 intensiv mit dem Lernfeld „Schutzbedarfsanalyse im eigenen Arbeitsbereich durchführen“ auseinandergesetzt.

Ausgangspunkt unserer Arbeit war die Rahmensituation des Hamburger Startups MooveTeq. Nach einem kritischen IT-Ausfall im Unternehmen war es unser Auftrag, das Thema Datensicherheit grundlegend neu zu bewerten, um zukünftige Schäden vom Betrieb abzuwenden. Im Fokus stand dabei die Frage, wie Schutzbedarfe analysiert, bewertet und durch gezielte Maßnahmen abgesichert werden können.

Im Folgenden findet Ihr unsere vollständige Dokumentation sowie alle im Prozess entstandenen Artefakte. Wir führen Euch darin durch:

- **Die Organisationsweise des Teams.**
- **Die genutzten Ressourcen zur Planung und Durchführung des Projekts.**
- **Die Planung und Durchführung der benötigten Recherche, um das Lernfeld erfolgreich zu bearbeiten.**
- **Die Durchführung einer strukturierten Schutzbedarfsanalyse.**
- Konkrete Handlungsempfehlungen zur Verbesserung der IT-Sicherheit bei MooveTeq.
- Selbstkritik, Selbsteinschätzung und Notenvorschlag.

Das Ziel hinter der Analyse für MooveTeq stand für uns als Gruppe ein klarer Lernauftrag. Es ging uns nicht nur darum, Tabellen auszufüllen, sondern die Denkweise moderner IT-Security zu verinnerlichen. Unsere Zielsetzung für dieses Lernfeld haben wir in drei Kernbereichen definiert:

Fachkompetenz: IT-Sicherheit systematisch verstehen

Wir wollten lernen, wie man „Sicherheit“ messbar macht. Das bedeutet für uns:

- Den **BSI-IT-Grundschutz** nicht nur als Theorie zu sehen, sondern als praktisches Werkzeugset anzuwenden.
- Ein Auge für Schwachstellen zu entwickeln – weg vom reinen „Funktionieren“ der IT, hin zum Schutz der Werte (**VIV-Schutzziele**).
- Die Komplexität einer Infrastruktur in handhabbare Bausteine (**INF, SYS, NET, APP**) zu zerlegen.

Methodenkompetenz: Agiles Arbeiten im Team

Ein weiteres Ziel war die Professionalisierung unserer Arbeitsweise. Wir haben die Chance genutzt, um:

- **Agile Workflows** (Trello, User Stories, Stand-ups) in einem realistischen Projektszenario zu testen.
- Wissensmanagement durch Tools wie **Notion** effizient zu gestalten.
- Den Transfer von technischem Fachwissen in eine **managementgerechte Aufbereitung** (Maßnahmenkatalog) zu üben.

Transferleistung: Vom Problem zur Lösung

Das wichtigste Lernziel war für uns die Brücke zwischen Theorie und Praxis:

- Wir wollten lernen, wie man aus trockenen Dokumenten (Grundrissen, Softwarelisten) ein realistisches Bedrohungsszenario ableitet.
- Das Ziel war es, am Ende nicht nur zu sagen „Das ist kaputt“, sondern fundiert zu begründen: „Das ist die Lösung, und so setzen wir sie um.“

Durch diese Zielsetzung wurde das Lernfeld für uns von einer reinen Schulaufgabe zu einer **Generalprobe für unser späteres Berufsleben** als IT-Spezialisten.

Wir freuen uns für euer Interesse und freuen uns auf den fachlichen Austausch.

Einführung in Szenario C

Nachdem wir uns einen Überblick über die verschiedenen Anforderungen verschafft hatten, fiel die Wahl unserer Gruppe einstimmig auf Szenario C. Ausschlaggebend für diese Entscheidung war zum einen der Impuls von Kerem, eine Herausforderung anzunehmen, sowie die Vorerfahrung von Thies, der bereits mit den Inhalten des Lernfeldes vertraut war.

Die Ausgangslage

Das Szenario führt uns direkt in das Herz der **MooveTeq-Krise** : Hunderte Scooter standen am Wochenende still, die App war tot und die Kundenzufriedenheit sank. Während unser Wettbewerber „ScooTeq“ von diesem Ausfall profitierte, wurde der Geschäftsführung klar, dass Datensicherheit kein „Nice-to-have“, sondern die Existenzgrundlage unseres Startups ist.

Unsere modifizierte Mission

Obwohl Szenario C ursprünglich eine Schutzbedarfsanalyse auf reinem BSI-Standardniveau vorsah, haben wir unser Vorgehen nach Rücksprache mit unseren Fachlehrern präzisiert und praxisnäher gestaltet.

Anstatt einer allgemeinen Analyse haben wir uns auf die vier Kernbereiche konzentriert, um die IT-Infrastruktur von MooveTeq schichtenweise abzusichern:

- **INF (Infrastruktur)**
- **SYS (Systeme)**
- **NET (Netzwerke)**
- **APP (Anwendungen)**

Für jeden dieser Bereiche haben wir jeweils **9** BSI-IT-Grundschutz-Bausteine detailliert erarbeitet. Dabei haben wir konsequent zwischen den Anforderungsniveaus **Basis, Standard und Hoch** unterschieden und pro Anforderungsniveau **drei** Bausteine gewählt die zu diesem Szenario passen, um für MooveTeq einen skalierbaren und zukunftssicheren Sicherheitskatalog zu erstellen.

Bevor wir jedoch in die Durchführung dieses Szenarios starten, kommen wir zu der Organisation des Teams.

Organisation

Um die Anforderungen von **Szenario C** strukturiert und effizient zu bewältigen, hat sich unsere Gruppe für eine moderne, agile Arbeitsweise entschieden. Unser Fokus lag dabei auf maximaler Transparenz und einer engen Verzahnung der einzelnen Arbeitsschritte.

Agile Workflow & knowledge transfer

Da ein Teil unseres Teams zuvor noch nicht mit agilen Methoden vertraut war, gab Thies zu Beginn eine kompakte Einführung in die Prinzipien des agilen Arbeitens.

Wir haben uns bewusst gegen starre Rollenverteilungen (wie z. B. einen dedizierten Scrum Master) entschieden. Aufgrund des Zeitdrucks und der überschaubaren Teamgröße wählten wir einen **„Lean-Agile“-Ansatz**. Das bedeutete für uns:

- **User Stories:** Wir haben unsere Aufgaben in klar definierte Stories unterteilt, um den Fokus immer auf dem Mehrwert für das Projekt zu behalten.
- **Daily Stand-ups:** Jeden Morgen fand ein kurzes Synchronisations-Meeting statt. Konnten wir nicht vor Ort in der Schule sein, haben wir diese Sessions flexibel per Online-Call durchgeführt.

(hier Trello Artefakte hinzufügen)

Unsere Tools



Für die Koordination und Ergebnissicherung haben wir auf bewährte digitale Werkzeuge gesetzt:

- **Trello** - Unser zentrales Kanban-Board. Hier behielten wir den Überblick über das Backlog, laufenden Sprints (Wöchentlicher Sprint) und erledigte Aufgaben (Done).
- **Notion -** Als „Single Source of Truth“ diente uns Notion zum Zusammentragen aller Artefakte, Dokumentations-Texte und Rechercheergebnisse. Als Enterprise Methode hätte man vermutlich Confluence benutzt.
- **WhatsApp** - Für das schnelle Team-Management, kurzfristige Absprachen und die interne Organisation im Alltag. Im Unternehmen hätte man vermutlich Enterprise Lösungen wie Teams oder Gmail verwendet.
- **Google Workspace** - Eine kostenlose Alternative zum Office 365, welche cloudbasiert ist und den Vorteil und Flexibilität von einfachen Teilen bietet.
- **Office 365 (Microsoft 365)** - Eine Sammlung an Tools für die Erstellung von Schriftlichen Dokumenten oder Tabellen.

Durch diese strukturierte Arbeitsweise konnten wir sicherstellen, dass trotz der parallelen Arbeit an den vier Bereichen (INF, SYS, NET, APP) alle Fäden am Ende konsistent zusammenlaufen und die erarbeiteten Dokumente und Ergebnisse von jedem Teammitglied Überprüft und verinnerlicht werden kann.

Recherche

Ein tiefgreifendes Verständnis der IT-Sicherheit ist die Voraussetzung für eine fundierte Analyse. Um sicherzustellen, dass die Gruppe mit einem einheitlichen Wissensstand in die Bearbeitung des Szenarios startet, haben wir die erste Phase des Lernfelds intensiv der Recherche gewidmet.

Einarbeitung

Das erste Wochenende haben wir genutzt, um uns eigenständig in die Strukturen des **BSI** (Bundesamt für Sicherheit in der Informationstechnik) einzuarbeiten. Als zentrale Quelle diente uns hierfür das Fachmodul:

> **„Datensicherheit im Kontext von IT-Grundschutz verstehen“**

Im Gegensatz zur späteren Spezialisierung in die Bereiche INF, SYS, NET und APP haben wir diesen Teil bewusst gemeinsam und synchron absolviert. Jeder im Team hat sich mit denselben Inhalten auseinandergesetzt, um ein identisches Basisverständnis für die IT-Schutzziele und die Methodik des BSI-Grundschutzes zu entwickeln

Vertiefung durch Inputs

Zusätzlich haben wir an dem angebotenen Input zum Thema Datensicherheit teilgenommen. Dieses halfe uns dabei:

- Die theoretischen Grundlagen der allgemeinen Datensicherheit zu verinnerlichen.
- Ein Bewusstsein für die Relevanz der Security-Awareness im Unternehmen zu entwickeln.
- Die Anforderungen für die Schutzbedarfsanalyse zu definieren

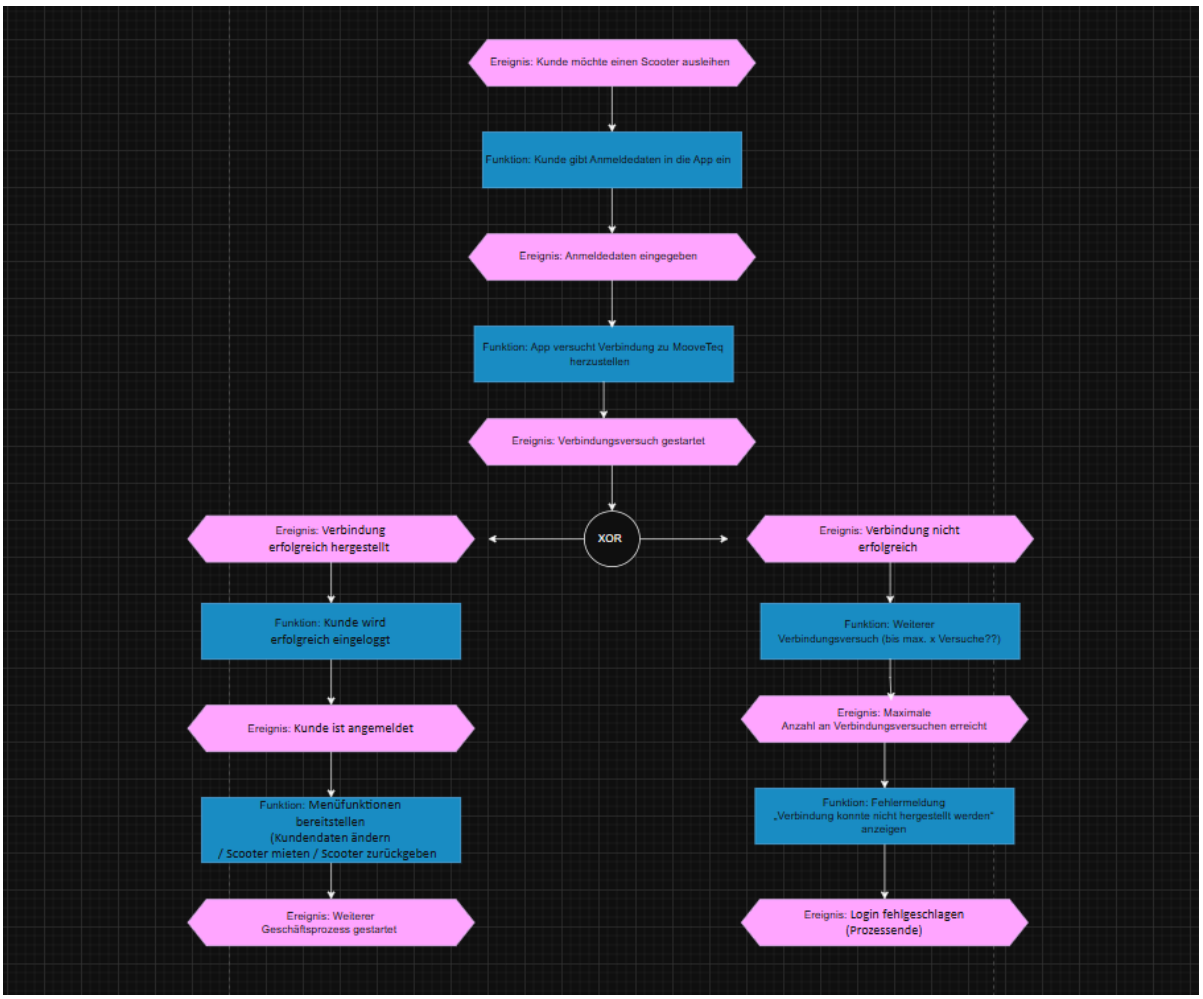
Durch diesen geschlossenen Wissensaufbau hatten wir nun einen besseren Überblick über folgende Aufgaben und konnten eine bessere Planung des Projekts verwirklichen.

Durchführung der Schutzbedarfsanalyse

Nach der theoretischen Einarbeitung sind wir in die praktische Umsetzung übergegangen. Dabei haben wir uns strikt an die vorgegebenen Teilhandlungsschritte gehalten, diese jedoch auf unsere spezifische Zielsetzung, die detaillierte Analyse der Bereiche **INF, SYS, NET und APP**, adaptiert.

Prozessanalyse (EPK)

Um die kritischen Punkte in der IT-Landschaft von MooveTeq zu identifizieren, haben wir zunächst den zentralen Geschäftsprozess „Scooter ausleihen“ visualisiert. Dies ermöglichte uns eine präzise Zuordnung der beteiligten IT-Assets.



Methodik der Analyse von Teilhandlung 4

Für die eigentliche Analyse haben wir die komplexen Anforderungen in spezialisierte Arbeitspakete unterteilt. Gemäß unserem agilen Ansatz übernahm jedes Teammitglied die Federführung für einen der vier Kernbereiche (Infrastruktur, Systeme, Netze oder Anwendungen).

Qualitätssicherung durch Validierung

Ein entscheidender Faktor für unsere Ergebnisse war der iterative Prozess:

- **Spezialisierung:** Jedes Mitglied erarbeitete tiefgehend die Bausteine für seinen Bereich.
- **Synchronisation:** Nach jedem Teilschritt (Strukturanalyse, Schutzbedarfsfeststellung, Modellierung) haben wir unsere Ergebnisse im Team verglichen und validiert.
- **Tracking:** Der Fortschritt und die Abhängigkeiten zwischen den Bereichen wurden kontinuierlich über unser Trello-Board gesteuert.

Dokumentation & Quellen

Für die Dokumentation haben wir uns an den Tabellenstrukturen orientiert, die im Fachmodul **„Schutzbedarfsanalyse nach IT-Grundschutz durchführen“** empfohlen wurden.

Als fundierte Datenbasis für unsere Analyse dienten die von MooveTeq bereitgestellten Dokumente:

- **Unternehmensprofil** der MooveTeq-GmbH.
- **Sicherheitsmanagement** der MooveTeq-GmbH.
- **Leitlinie zur Informationssicherheit** der MooveTeq-GmbH.
- **Softwarestand Client**
- **Beschreibung des IT-Arbeitsplatzes**
- **Grundriss Büro**

Durch diese methodische Trennung und anschließende Zusammenführung konnten wir sicherstellen, dass trotz der individuellen Bearbeitung ein konsistentes und hochprofessionelles Gesamtbild der Sicherheitslage entstand.

Ergebnisse von Teilhandlung 4-1 (Strukturanalyse)

Die Strukturanalyse bildete das Fundament unserer Schutzbedarfsanalyse. Unser Ziel in diesem Schritt war es, eine lückenlose Übersicht über alle für MooveTeq relevanten Objekte zu schaffen, um darauf aufbauend die Sicherheitsanforderungen präzise definieren zu können.

Basierend auf den bereitgestellten Unternehmensdokumenten – wie dem Unternehmensprofil, dem Grundriss des Büros und dem aktuellen Softwarestand – haben wir die IT-Landschaft in vier detaillierten Tabellen erfasst:

- **Geschäftsprozesse (vom Lernfeld gefordert):** Identifikation der wertschöpfenden Abläufe (Fokus: „Scooter ausleihen“).
- **Räume (INF):** Erfassung der physischen Infrastruktur und deren Absicherung.
- **IT-Systeme (SYS):** Bestandsaufnahme der eingesetzten Hardware und Server-Komponenten.
- **Anwendungen (APP):** Auflistung der Softwarelösungen, die für den Betrieb kritisch sind.

wir haben uns an folgendem tabellen layout orientiert:

Bezeichnung	Beschreibung des Objekts	Standort	Anzahl	Status	Benutzer	Verantwortlich
SW_O02		Ohlsdorf	1	im Betrieb	Administratoren	IT-Abteilung (Ohlsdorf)

Bereits in dieser frühen Phase der Analyse konnten wir durch die strukturierte Gegenüberstellung der Daten erste kritische Schwachstellen identifizieren. Besonders in den Bereichen **Infrastruktur (INF)** und **Systeme (SYS)** fielen uns Sicherheitslücken auf, die

potenzielle Angriffsvektoren darstellen könnten. Ein Beispiel hierfür ist die Platzierung und die mangelnde physische Zugangskontrolle des Serverschranks, was ein erhebliches Risiko für die Hardware-Integrität darstellt.

Diese ersten Beobachtungen dienten uns als wichtiger Indikator für die spätere Detail-Analyse und die Auswahl der entsprechenden BSI-Bausteine. Eine vertiefte Bewertung dieser Schwachstellen erfolgt im weiteren Verlauf der Dokumentation.

Ergebnis Dateien der Teilhandlung

Ergebnisse von Teilhandlung 4-2 (Schutzbedarfsfeststellung)

Nachdem wir in der Strukturanalyse die relevanten Objekte identifiziert haben, bestand der nächste Schritt darin, den konkreten Schutzbedarf für jedes dieser Elemente zu evaluieren. Ziel war es, festzulegen, wie kritisch ein Verlust der Sicherheitseigenschaften für die **MooveTeq GmbH** wäre.

Die VIV-Methodik

ür eine fundierte Bewertung haben wir jedes Objekt anhand der drei klassischen Grundwerte der Informationssicherheit (VIV) untersucht:

- **Vertraulichkeit:** Schutz vor unbefugter Preisgabe von Informationen.
- **Integrität:** Sicherstellung der Korrektheit (Unversehrtheit) von Daten und Systemen.
- **Verfügbarkeit:** Gewährleistung, dass Systeme und Daten bereitstehen, wenn sie benötigt werden.

Systematische Bewertung

Um eine konsistente Einstufung zu gewährleisten, haben wir erneut **vier** spezialisierte Tabellen (INF, SYS, NET und APP) erstellt. Dabei haben wir uns eng an der Methodik und den Beispielstrukturen des Fachmoduls **„Schutzbedarfsanalyse nach IT-Grundschutz durchführen“** orientiert.

Für jedes Objekt haben wir die möglichen Schadensszenarien betrachtet und den Schutzbedarf in die Kategorien **Normal**, **Hoch** oder **sehr Hoch** eingestuft.

Beispiel layout der Tabelle:

Bezeichnung	Beschreibung	Vertraulichkeit	Integrität	Verfügbarkeit	Begründung
A001		normal	hoch	sehr hoch	

Diese detaillierte Schutzbedarfsfeststellung war für uns essenziell, da sie das notwendige Fundament für den nächsten Projektschritt bildet. Erst durch die klare Definition der Schutzziele (VIV) konnten wir in **Kapitel 4.3 (Modellierung)** die passenden IT-Grundschutz-Bausteine auswählen, die exakt auf das Risikoprofil von MooveTeq zugeschnitten sind.

Ergebnis Dateien der Teilhandlung

Ergebnisse von Teilhandlung 4-3 (Modellierung)

In der Phase der Modellierung haben wir die Brücke zwischen den identifizierten Schutzbedarfen und den konkreten Sicherheitsmaßnahmen geschlagen. Ziel war es, für unsere Zielobjekte (INF, SYS, NET und APP) die passenden Bausteine aus dem **BSI-IT-Grundschutz-Kompendium** auszuwählen und das jeweils erforderliche Sicherheitsniveau zu definieren.

Systematische Auswahl und Anforderungsniveaus

Um eine präzise und dennoch fokussierte Analyse zu gewährleisten, haben wir uns in unseren bewährten Arbeitspaketen auf insgesamt **neun zentrale Objekte** konzentriert. Dabei haben wir konsequent eine Verteilung vorgenommen, die alle drei Anforderungsniveaus des BSI abbildet:

- **Basis-Anforderungen (3 Objekte):** Maßnahmen, die als unverzichtbares Mindestmaß für die Sicherheit gelten.
- **Standard-Anforderungen (3 Objekte):** Maßnahmen, die für einen angemessenen Schutz unter normalen Bedingungen sorgen.
- **Anforderungen bei hohem Schutzbedarf (3 Objekte):** Spezifische, weiterführende Maßnahmen für besonders kritische Assets von MooveTeq.

Für jeden ausgewählten Baustein haben wir nicht nur das Level festgelegt, sondern dieses auch detailliert **begründet**. Dieser Prozess war für unser Team besonders aufschlussreich: Durch die Gegenüberstellung der Niveaus erhielten wir einen direkten Einblick, welche Maßnahmen lediglich das „Pflichtprogramm“ zur Schadensabwehr darstellen und welche zusätzlichen Implementierungen sinnvoll sind, um die Resilienz des Unternehmens nachhaltig zu steigern.

Diese Differenzierung ermöglicht es uns, der Geschäftsführung von MooveTeq später fundierte Empfehlungen zu geben, die über eine reine Standard-Absicherung hinausgehen.

Beispiellayout unserer Tabelle:

BSI Baustein (SYS)	ID-Anforderung	Zielobjekt (ID)	Anforderungslevel	Ansprechpartner	Relevanz	Begründung	Kommentar
SYS.2.1 Allgemeiner Client	A1 Sichere Authentisierung von Benutzenden	C_S01, C_O01	Basis	IT-Abteilung	Ja		

Ergebnis Dateien der Teilhandlung

Ergebnisse von Teilhandlung 4-4 (IT-Grundschutz-Check - Soll-Ist-Vergleich)

Im letzten Schritt unserer Schutzbedarfsanalyse haben wir die theoretischen Anforderungen aus der Modellierung (Kapitel 4.3) der praktischen Realität bei **MooveTeq** gegenübergestellt. Dieser IT-Grundschutz-Check diente als finaler Prüfstand, um genau zu identifizieren, wo das Unternehmen bereits gut aufgestellt ist und wo akuter Handlungsbedarf besteht.

Der Soll-Ist-Vergleich

Für unsere neun ausgewählten Fokus-Objekte haben wir einen systematischen Abgleich durchgeführt. Dabei haben wir die Informationen aus der **Unternehmensdokumentation**, dem **Grundriss** und der **Strukturanalyse** als „Ist-Zustand“ herangezogen und gegen die „Soll-Vorgaben“ der BSI-Bausteine geprüft.

Dieser Prozess war entscheidend, um die abstrakten Sicherheitsanforderungen in greifbare Fakten zu übersetzen. Wir haben dabei folgende Fragen beantwortet:

- Welche der Basis- und Standard-Anforderungen werden bereits erfüllt?
- Wo klaffen Sicherheitslücken, die den Betrieb gefährden könnten?
- Welche spezifischen Risiken ergeben sich aus der aktuellen Infrastruktur?

Auch für diesen Schritt haben wir eine übersichtliche Tabellenstruktur gewählt, die den Status (Erfüllt / Teilweise Erfüllt / Nicht Erfüllt) sowie die daraus resultierende Maßnahme pro Objekt transparent darstellt.

Anforderung (SYS)	**Verantwortung**	**Status**	**Umsetzung**	**Begründung (Info-Quelle)**
SYS.2.1 A1: Sichere Authentisierung von Benutzenden	IT-Abteilung	erfüllt	Zugriff auf das Netz erfolgt mittels Authentisierung und VPN.	Unternehmensbeschreibung: „Zugriff auf das Unternehmensnetz erfolgt bei Bedarf mittels Authentisierung und VPN.“

Ergebnis Dateien der Teilhandlung

Mit diesem Kapitel schließen wir die operative Phase der Schutzbedarfsanalyse ab. Die hier erarbeiteten Ergebnisse bilden die perfekte Grundlage, um der Geschäftsleitung eine fundierte Entscheidungsvorlage für die zukünftige IT-Sicherheitsstrategie zu präsentieren, welches in den nächsten Kapitel durchgeführt wird.

Strategischer Maßnahmenkatalog

Basierend auf unserem IT-Grundschutz-Check haben wir einen Maßnahmenkatalog entwickelt. Um der Geschäftsführung eine effiziente Entscheidungsfindung zu ermöglichen, haben wir die Empfehlungen nach **Umsetzungsaufwand** und **Risikopotenzial** gewichtet.

1. Sofortmaßnahmen (Geringer Aufwand – Hohe Wirkung)

Diese Maßnahmen beheben offensichtliche Schwachstellen, die derzeit ein unnötig hohes Risiko für den Betrieb darstellen, und können kurzfristig umgesetzt werden.

- **Physische Sicherung der Hardware:** Der Server muss umgehend aus dem offenen IT-Büro in einen abschließbaren, nicht öffentlich zugänglichen Bereich verlagert werden. Dies verhindert unbefugten physischen Zugriff und Manipulationen.
- **Kabelmanagement & Arbeitssicherheit:** Die „fliegende Verkabelung“ im Büro und an den Arbeitsplätzen muss durch Kabelkanäle und Bodenschutz ersetzt werden (INF.10.A5). Dies minimiert das Risiko von versehentlichen Betriebsunterbrechungen durch Stolpern oder gezogene Stecker.
- **Sensibilisierung der Belegschaft:** Durchführung einer kurzfristigen Security-Awareness-Schulung für alle Mitarbeiter (APP.1.1.A17), um den Umgang mit externen Dokumenten und aktiven Inhalten (Makros) zu professionalisieren. Dafür kann der beigefügte Flyer verwendet werden.
- **Sichtschutzfilter:** Ausrüstung aller Monitore in öffentlich zugänglichen Bereichen (z. B. Erdgeschoss) mit Blickschutzfolien (INF.7.A5), um das Ausspähen von Kundendaten durch Passanten oder Besucher zu verhindern.

2. Kritische Defizite: Strukturelle Absicherung (Hohes Risiko)

Diese Punkte betreffen die Kernarchitektur unserer IT-Sicherheit. Ein Versäumnis in diesen Bereichen kann bei einem erneuten Vorfall existenzbedrohende Folgen haben.

- **Etablierung eines Notfallmanagements:** Die Entwicklung und Dokumentation eines Notfallplans (SYS.1.1.A22) sowie einer spezifischen Vorsorge für Datenbanken (APP.4.3.A22) ist zwingend erforderlich. Nur so kann bei einem Systemausfall ein schneller Wiederanlauf gewährleistet werden.
- **Härtung der Netz-Infrastruktur:** * Deaktivierung aller ungenutzten Switch-Ports (NET.3.1.A19), um unbefugtes „Einstöpseln“ im Büro zu verhindern.
    - Implementierung einer Statusüberwachung (Monitoring) für alle aktiven Netzkomponenten (NET.1.2.A25), um Unregelmäßigkeiten proaktiv zu erkennen, bevor sie zum Ausfall führen.
- **Datenverschlüsselung & Zugriffsschutz:** Die Verschlüsselung der Massenspeicher auf den Servern sowie die Reaktivierung der TPM-Module muss umgesetzt werden (APP.3.3.A12). Ergänzend ist ein VPN-Konzept zur sicheren Remote-Anbindung zu finalisieren.

Zusammenfassende Empfehlung der Gruppe 11

Wir empfehlen, die **physische Absicherung (Raumkonzept & Verkabelung)** sowie die **Notfallplanung** mit höchster Priorität zu behandeln. Während technische Konfigurationen im Hintergrund optimiert werden können, stellen die physische Zugänglichkeit der Server und das Fehlen von Wiederanlaufplänen derzeit die größten Schwachstellen in der Business Continuity von MooveTeq dar.



Datein für den Flyer

Gruppen Organisation und Ressourcen
- Selbsteinschätzung Orga

Kompetenzbogen vorher
Recherche
- Selbsteinschätzung

Teilhandlungen 1-6
- Selbsteinschätzung

Konkrete Maßnahmen für MOOVETEQ
Selbsteinschätzung und Fazit

Konkrete Maßnahmen für MOOVETEQ

Aus dem vorangegangenen Soll-Ist-Vergleich ergeben sich notwendige Handlungsschritte, um die identifizierten Sicherheitsrisiken zu minimieren. Die folgenden Maßnahmen verfolgen einen ganzheitlichen Ansatz aus Technik, Organisation und Personal. Ziel ist es, die IT-Resilienz zu stärken und die Geschäftskontinuität sicherzustellen, indem klare Vorgaben für das Unternehmen sowie verbindliche Verhaltensregeln für die Mitarbeitenden definiert werden.

Identifizierte Gefahren (Risikoanalyse)

Die aktuelle Situation der IT-Infrastruktur birgt verschiedene Bedrohungsszenarien:

1. Physische Sabotage und Diebstahl: Durch die Platzierung zentraler IT-Komponenten (Server) in öffentlich zugänglichen Büroräumen im Erdgeschoss besteht ein hohes Risiko für Diebstahl oder physische Manipulation. „Fliegende Verkabelungen“ erhöhen zudem die Gefahr von unbeabsichtigten Betriebsunterbrechungen durch Stolpern oder versehentliches Herausziehen von Kabeln.
2. Informationsabfluss durch mangelnde Diskretion: Frei zugängliche Faxgeräte und Drucker sowie fehlender Sichtschutz an Monitoren in Publikumsbereichen ermöglichen Unbefugten (z. B. Besuchern oder Reinigungskräften) den Einblick in sensible Unternehmensdaten.
3. Unbemerkte Netzwerkinfiltration: Da keine Protokollierung und Auswertung der Firewall-Logs (Logging & Monitoring) stattfindet und ungenutzte Switchports aktiv bleiben, können Cyberangriffe oder unbefugte Hardware im Netzwerk über lange Zeit unentdeckt bleiben.
4. Totalverlust von Daten bei Notfällen: Das Fehlen eines dokumentierten Notfallplans sowie mangelnde Redundanz (keine USV, keine Server-Spiegelung) führt dazu, dass das Unternehmen bei einem Hardwaredefekt oder Brand nicht zeitnah handlungsfähig ist (Existenzrisiko).
5. Rechtliche und regulatorische Verstöße: Durch das Deaktivieren von Verschlüsselungsmechanismen (TPM) und das Fehlen eines Berechtigungskonzepts werden Anforderungen des Datenschutzes (DSGVO) nur unzureichend erfüllt.

3.2 Empfohlene Maßnahmen zur Risikominimierung

Um die identifizierten Gefahren zu terminieren oder deren Auswirkungen abzumildern, sind sowohl organisatorische als auch technische Maßnahmen erforderlich.

Maßnahmen für das Unternehmen (Organisatorisch & Infrastrukturell):

- Härtung der physischen Infrastruktur: Der Server muss aus dem IT-Büro in einen abschließbaren, klimatisierten Bereich verlagert werden. Die Verkabelung ist in festen Kabelkanälen zu führen, um mechanische Einflüsse zu minimieren.
- Einführung eines Notfallmanagements: Erstellung eines Business Continuity Plans (BCP), der klare Zuständigkeiten und Wiederherstellungsszenarien (Backup/Restore) definiert.
- Technische Absicherung der Netzübergänge: Aktivierung eines zentralen Log-Managements für die Firewall sowie die Umsetzung einer starken Multifaktor-Authentisierung (MFA) für den VPN-Zugriff.
- Richtlinienkompetenz: Erstellung und Inkraftsetzung eines Berechtigungskonzepts sowie einer verbindlichen Passwortrichtlinie.

Maßnahmen für die Mitarbeitenden (Verhaltensprävention):

- Sensibilisierung (Security Awareness Training) Um Gefahren wie Phishing oder die Risiken durch aktive Inhalte in Office-Dokumenten (vgl. APP.1.1.A17) zu begegnen, ist die Durchführung regelmäßiger Sicherheitsschulungen essenziell. Die Mitarbeitenden müssen befähigt werden, schädliche Dateianhänge zu identifizieren und den korrekten

Meldeweg bei Sicherheitsvorfällen einzuhalten. Ziel ist es, ein proaktives Gefahrenbewusstsein zu schaffen, das über das bloße Befolgen von Regeln hinausgeht.

- Arbeitsplatzdisziplin (Clean Desk & Screen Policy) Angesichts der offenen Bürogruppierung und der frei zugänglichen Fax- und Druckgeräte (vgl. SYS.4.1 A1) ist die konsequente Umsetzung einer „Clean Desk Policy“ zwingend erforderlich. Mitarbeitende werden dazu verpflichtet, sensible Unterlagen beim Verlassen des Platzes wegzuschließen und den Bildschirm mittels Tastenkombination (Windows + L) zu sperren. Zudem ist die unmittelbare Entnahme von Ausdrucken und Faxen aus den öffentlich zugänglichen Geräten als Verhaltensnorm zu etablieren.
- Geräte-Compliance (Hardware-Integrität) Trotz des bestehenden Verbots privater Hardware (BYOD) muss die Belegschaft kontinuierlich über die Risiken unbefugter Hardware-Nutzung aufgeklärt werden. Dies umfasst auch den physischen Schutz der ausgegebenen mobilen Endgeräte (z. B. Notebooks) vor Diebstahl oder unbefugtem Zugriff durch Dritte im Homeoffice oder auf Dienstreisen. Die strikte Trennung von geschäftlicher und privater Nutzung ist hierbei die zentrale Verhaltensvorgabe.
- Authentisierungsdisziplin (Umgang mit Zugangsdaten) Mitarbeitende müssen für den sicheren Umgang mit Identitäten und den dazugehörigen Authentisierungsmitteln (Passwörter, VPN-Token) sensibilisiert werden. Dazu gehört die Wahl starker Passwörter sowie das Verbot, Zugangsdaten im Browser zu speichern oder physisch am Arbeitsplatz zu notieren. Die korrekte Nutzung der VPN-Infrastruktur für jeglichen Fernzugriff ist als obligatorischer Standard für die mobile Arbeit zu verankern.

4. Fazit

Die Analyse zeigt, dass insbesondere im Bereich der physischen Absicherung und der Dokumentation kritische Lücken bestehen. Während grundlegende technische Werkzeuge (VPN, Firewall) vorhanden sind, fehlt es an der Tiefe der Konfiguration und an verbindlichen Prozessen. Durch die Umsetzung der oben genannten Maßnahmen kann das Sicherheitsniveau signifikant gesteigert und die Resilienz des Unternehmens gegenüber internen und externen Bedrohungen gestärkt werden.